Matriz de Riesgos — ReMarket

> **Escala:** Alto = 3 · Medio = 2 · Bajo = 1 · **Nivel = Impacto × Probabilidad**
> **Clasificación:** 6–9 Alto · 3–4 Medio · 1–2 Bajo

1. Identificación y Valoración de Riesgos

#	Riesgo	Activo Expuesto	Amenaza	Vulnerabilidad	Impacto (I)	Probabilidad (P)	Nivel ($I \times P$)	Clasificación
R1	Fuga de API keys o credenciales en repositorios Git	Acceso general a la nube y APIs	Robo o filtración de claves	Secretos quemados en código fuente (*hardcoded*)	3	2	**6**	**Alto**
R2	Intercepción de tráfico este-oeste (Man-in-the-Middle)	Datos de usuarios y órdenes en red	Eavesdropping / Spoofing de pods	Red interna asumida como confiable sin mTLS	3	1	**3**	**Medio**
R3	Exfiltración de respaldos o volúmenes sin cifrar	BD PostgreSQL y copias WAL	Volcado no autorizado de datos	Discos o snapshots sin cifrado de sobre (KMS)	3	2	**6**	**Alto**
R4	Caída del servicio por ataque DDoS en temporada alta	API Gateway y frontend web	Inundación masiva L3/L4 y L7	Falta de rate-limiting o capacidad elástica	3	3	**9**	**Alto**
R5	Inyección de dependencia maliciosa en el pipeline	Imágenes de contenedor en EKS	Supply chain attack / Backdoors	Falta de análisis SCA y admisión sin firma OCI	3	2	**6**	**Alto**
R6	Falsificación de webhook de pasarela de pagos	Transacciones financieras	Confirmación ilegítima de cobros	Validación ausente de firma HMAC o replay	3	2	**6**	**Alto**
R7	Caída del proveedor de SMS	Avisos por SMS al cliente	Interrupción del servicio del tercero	Un solo proveedor de SMS	1	2	**2**	**Bajo**

Cobertura de Categorías Obligatorias

Categoría Obligatoria	Riesgo que la Cubre	Nivel Asignado
Credenciales	**R1:** Fuga de API keys y credenciales en repositorios	Alto (6)
Comunicaciones	**R2:** Intercepción de tráfico este-oeste entre microservicios	Medio (3)
Almacenamiento	**R3:** Exfiltración de respaldos o volúmenes sin cifrar	Alto (6)
Disponibilidad	**R4:** Caída del e-commerce por ataque DDoS en temporada alta	Alto (9)
Cadena de Suministro / Pipeline	**R5:** Inclusión de dependencias vulnerables o imágenes adulteradas	Alto (6)
Terceros / Pagos (Opcional)	**R6:** Falsificación de confirmaciones en el webhook de pagos	Alto (6)
Terceros (Opcional)	**R7:** Caída del proveedor de SMS	Bajo (2)

2. Tratamiento de los Riesgos Prioritarios

R1 — Fuga de Credenciales en Repositorios de Código

Dimensión	Detalle del Control
Nivel	**6 (Alto)**
Tratamiento	✅ Mitigación
Control Preventivo	Pre-commit hooks con **Gitleaks**; runners de CI/CD autenticados exclusivamente mediante roles **OIDC** efímeros de 15 minutos (sin claves estáticas).
Control Detectivo	Escaneo continuo de commits con **TruffleHog**; monitoreo de llamadas anómalas a APIs en **AWS CloudTrail**.
Control Correctivo	Revocación inmediata en **AWS Secrets Manager**, rotación forzosa automatizada e invalidación de sesiones activas.
Riesgo Residual	**2 (Bajo):** Riesgo mitigado a errores manuales de configuración aislados.

R2 — Ataque Man-in-the-Middle en Red Interna

Dimensión	Detalle del Control
Nivel	**3 (Medio)** — probabilidad baja: el atacante necesita estar ya dentro del clúster.
Tratamiento	✅ Mitigación
Control Preventivo	Malla **Istio** forzando **mTLS estricto** con identidades SPIFFE y certificados de la CA de Istio rotados cada 24 horas.
Control Detectivo	Inspección de bitácoras de acceso en proxies Envoy y alertas SIEM ante intentos de conexión TLS con CAs no confiables.
Control Correctivo	Aislamiento automático del pod sospechoso mediante NetworkPolicy de cuarentena.
Riesgo Residual	**1 (Bajo):** El tráfico este-oeste viaja cifrado y autenticado criptográficamente.

R3 — Exfiltración de Respaldos o Discos sin Cifrar

Dimensión	Detalle del Control
Nivel	**6 (Alto)**
Tratamiento	✅ Mitigación
Control Preventivo	**AES-256-GCM** con *Envelope Encryption*; KEKs no exportables en **AWS KMS**; respaldos cifrados con una clave distinta, copiados a otra cuenta con **S3 Object Lock**.
Control Detectivo	Alarmas de KMS en CloudWatch ante accesos o solicitudes inusuales de descifrado (*kms:Decrypt*).
Control Correctivo	Revocar el rol o la política que permitió el acceso y rotar la KEK. Deshabilitar la KEK vuelve ilegible lo exfiltrado, pero también detiene a ReMarket, así que se reserva para un compromiso confirmado de la clave.
Riesgo Residual	**2 (Bajo):** Los datos almacenados son criptogramas ilegibles sin autorización del HSM.

R4 — Caída por Ataque DDoS Masivo en Temporada Alta

Dimensión	Detalle del Control
Nivel	**9 (Alto)**
Tratamiento	✅ Mitigación + 🔁 Transferencia (la protección de costos de Shield Advanced cubre el gasto de escalado causado por un DDoS)

Dimensión	Detalle del Control
Control Preventivo	Red Anycast global de **Amazon CloudFront**, protección L3/L4 con **AWS Shield Advanced** y reglas de WAF rate-limiting (500 req/min por IP).
Control Detectivo	Detección automática de anomalías en CloudFront y métricas de saturación en CloudWatch.
Control Correctivo	Autoescalado horizontal (HPA y Karpenter), *runbook* de respuesta a DDoS y reglas WAF de emergencia.
Riesgo Residual	**3 (Medio) — Aceptado:** ataques extraordinarios pueden subir la latencia; el costo de eliminarlo por completo no se justifica.

R5 — Inyección de Vulnerabilidades en la Cadena de Suministro

Dimensión	Detalle del Control
Nivel	**6 (Alto)**
Tratamiento	✅ Mitigación
Control Preventivo	Análisis SCA bloqueante con **Snyk/Trivy** (CVSS ≥ 7.0); imágenes Distroless rootless; firma digital OCI con **Sigstore Cosign**.
Control Detectivo	Verificación de firma criptográfica en el controlador de admisión (*Admission Webhook*) de Kubernetes antes de desplegar pods.
Control Correctivo	Rechazo de despliegue en ArgoCD y rollback automático a la última versión firmada estable.
Riesgo Residual	**2 (Bajo):** Solo código auditado y artefactos verificados llegan a producción.

R6 — Falsificación de Notificaciones de Pago (Webhook Spoofing)

Dimensión	Detalle del Control
Nivel	**6 (Alto)**
Tratamiento	✅ Mitigación + 🔁 Transferencia (el manejo de datos de tarjeta queda en Stripe, PCI-DSS SAQ-A)
Control Preventivo	Validación de firma **HMAC-SHA256** con secreto compartido en Secrets Manager; ventana de 300 s; registro de `event.id` procesados.
Control Detectivo	Registro en SIEM de notificaciones con firmas inválidas o desfasadas temporalmente.
Control Correctivo	Bloqueo de la IP agresora en WAF y conciliación con la API de Stripe (`GET /v1/payment_intents/{id}`, comparando monto y moneda).
Riesgo Residual	**1 (Bajo):** Fraude evitado mediante criptografía simétrica y verificación cruzada.

R7 — Caída del Proveedor de SMS

Dimensión	Detalle del Control
Nivel	**2 (Bajo)**
Tratamiento	🟦 Aceptación
Justificación	El correo sigue funcionando y un SMS retrasado no detiene ventas; un segundo proveedor costaría más que el daño esperado.
Control Detectivo	Alarma por tasa de errores del proveedor en CloudWatch.

3. Trazabilidad: Control Propuesto → Riesgo Mitigado

Control Propuesto en la Arquitectura	Sección del Documento Técnico	Riesgo que Mitiga
Pre-commit hooks con Gitleaks y roles temporales OIDC	Sección 08 y 12	**R1:** Fuga de credenciales
Malla Istio con mTLS estricto e identidades SPIFFE	Sección 04	**R2:** Intercepción este-oeste
Envelope Encryption (KMS) y S3 Object Lock (WORM)	Sección 06	**R3:** Exfiltración de almacenamiento
CloudFront CDN, AWS Shield y WAF Rate Limiting	Sección 01 y 15	**R4:** Ataques DDoS
Análisis SCA (Trivy/Snyk) y firma OCI con Cosign	Sección 12	**R5:** Cadena de suministro
Firma HMAC-SHA256, `event.id` único y verificación con Stripe	Sección 09	**R6:** Webhook falso de pagos
Hashing de contraseñas con Argon2id + salt CSPRNG	Sección 07	**R1:** Compromiso offline de contraseñas
Tokenización delegada en pasarela (PCI-DSS SAQ-A)	Sección 09	**R6** (transferencia): ReMarket no maneja datos de tarjeta
Firma ECDSA de `PedidoPagado` en KMS	Sección 11	**R6:** evento de pago falso en el bus
Contenedores Distroless rootless y NetworkPolicies	Sección 13	**R2 y R5:** Movimiento lateral y escape